

AAA und 802.1x

IT-SICHERHEIT / SEMESTER 5 UND 6



1

AGENDA

- 01 AAA ÜBERBLICK
- 02 RADIUS
- 03 802.1X

2

01

AAA Überblick

3

IT-SICHERHEIT / SEMESTER 5 und 6

AAA Komponenten

Netzwerk- und administrative AAA-Sicherheit umfasst drei funktionale Komponenten:

- **Authentifizierung** – Benutzer und Administratoren müssen ihre Identität nachweisen, bevor sie auf das Netzwerk und dessen Ressourcen zugreifen können. Die Authentifizierung kann mittels Benutzername-Passwort-Kombinationen, Sicherheitsfragen, Token-Karten und anderen Methoden erfolgen. Beispiel: „Ich bin Benutzer ‚student‘ und kenne das Passwort.“
- **Autorisierung** – Nach erfolgreicher Authentifizierung legen Autorisierungsdienste fest, auf welche Ressourcen der Benutzer zugreifen und welche Aktionen er ausführen darf. Beispiel: „Benutzer ‚student‘ kann nur per SSH auf Host serverXYZ zugreifen.“
- **Protokollierung und Überwachung** – Die Protokollierung erfasst die Benutzeraktivitäten, einschließlich der aufgerufenen Ressourcen, der Zugriffsdauer und vorgenommenen Änderungen. Sie überwacht die Nutzung der Netzwerkressourcen. Beispiel: „Benutzer ‚student‘ hat 15 Minuten lang per SSH auf Host serverXYZ zugegriffen.“

4

AAA Komponenten

AAA

- Authentifizierung, Autorisierung, Abrechnung
- RFC 2903 (Generische AAA-Architektur)
- RFC 2904 (AAA-Autorisierungsframework)

AAAA

- AAA und Auditierung

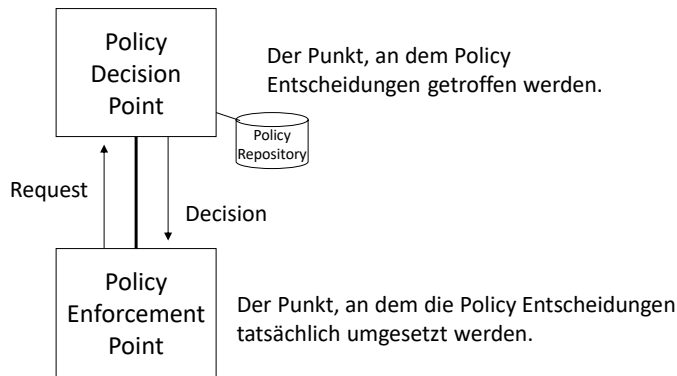
Abrechnung und Fakturierung

- Abrechnung bezeichnet die Erfassung von Informationen für die Fakturierung, den Kontoausgleich oder andere Zwecke.
- Fakturierung ist der Prozess der Rechnungserstellung für Kunden auf Basis der erfassten Informationen.

AAA Motivation

- **Serviceorganisationen** betreiben zentral Einwahldienste für mehrere Kundenorganisationen.
- **Nutzerorganisationen** können Authentifizierungs- und Zugriffsdienste an spezialisierte Dienstleister auslagern.
- **RADIUS** schafft durch einen etablierten Standard die Grundlage für die Zusammenarbeit zwischen Organisationen.
- **Flexibilität und Anbieterunabhängigkeit:** Nutzerorganisationen können den Serviceprovider wechseln, ohne ihre Nutzerinfrastruktur grundlegend anzupassen.
- **Proxy-AAA** ermöglicht Agenten und Dienstleistern, ihre Backend-Services auszutauschen oder zu erweitern, ohne bestehende Kundenbeziehungen zu beeinträchtigen.
- **Klare Verantwortlichkeiten:** Jede Serviceorganisation behält die vollständige Kontrolle über ihre eigenen Benutzer, Rollen und Richtlinien.

Generic AAA Architektur (RFC2903)

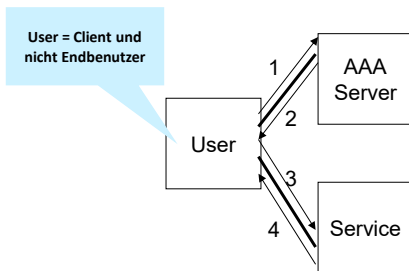


7

AAA Modelle Single Domain (RFC2904)

Push Modell

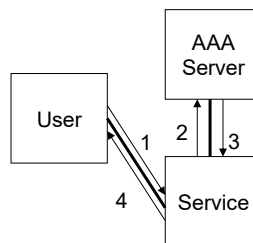
User bringt die Erlaubnis selbst mit.



Ticket- oder
Zertifikatsbasierter Zugang
(Kerberos, OAuth, ...)

Pull Modell

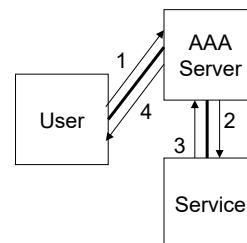
Service fragt AAA nach Erlaubnis.



Klassischer RADIUS Dial-In
oder VPN-Zugang

Agent-/Proxy-AAA-Modell

AAA sagt dem Service, was zu tun ist.



Bandwidth Broker / QoS

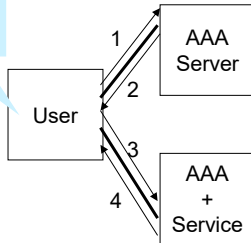
8

AAA Modelle Roaming(RFC2904)

Push Modell

Die Heimatorganisation verteilt Benutzerdaten an Serviceprovider.

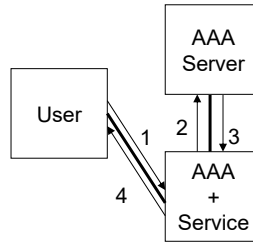
User = Client und nicht Endbenutzer



Mobilfunkanbieter mit Partnernetz

Pull Modell

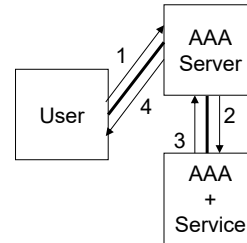
Der Serviceprovider fragt Benutzerdaten bei Bedarf ab.



WLAN-Hotspot eines Flughafens

Agent-/Proxy-AAA-Modell

Vermittler leitet AAA-Anfragen zwischen beteiligten Org. weiter.



eduroam

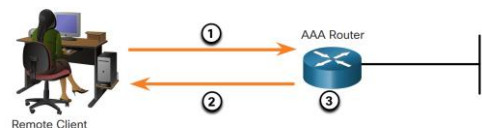
Authentifizierungsmodi

Typischerweise werden zwei gängige Methoden zur Implementierung von AAA-Diensten angeboten:

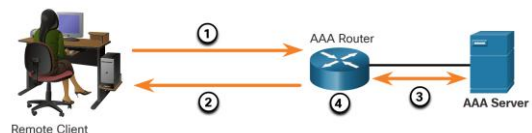
- **Lokale AAA-Authentifizierung** – Die lokale AAA-Authentifizierung nutzt eine lokale Datenbank. Diese Methode wird auch als eigenständige Authentifizierung bezeichnet.
- **Serverbasierte AAA-Authentifizierung** – Bei der serverbasierten Methode greift der Router auf einen zentralen AAA-Server zu, beispielsweise FreeRADIUS, Cisco ISE, Microsoft NPS, Tacacs.net und Authentik / Keycloak.

Der zentrale AAA-Server enthält die Benutzernamen und Passwörter aller Benutzer.

Der Router kommuniziert mit dem AAA-Server entweder über das **RADIUS-Protokoll (Remote Authentication Dial-In User Service)** oder über das **TACACS+-Protokoll (Terminal Access Controller Access Control System)**.



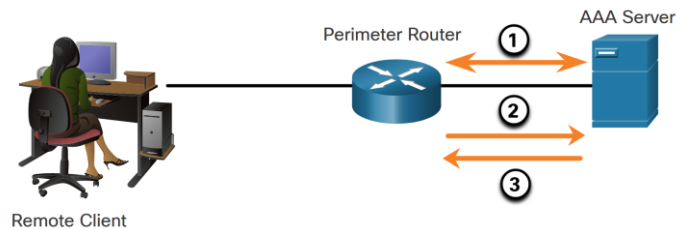
1. The client establishes a connection with the router.
2. The AAA router prompts the user for a username and password.
3. The router authenticates the username and password using the local database and the user is provided access to the network based on information in the local database.



1. The client establishes a connection with the router.
2. The AAA router prompts the user for a username and password.
3. The router authenticates the username and password using a AAA server.
4. The user is provided access to the network based on information in the remote AAA server.

Autorisierung

Nachdem die Benutzer erfolgreich gegenüber der ausgewählten AAA-Datenquelle, sei es lokal oder serverbasiert, authentifiziert wurden, werden sie für bestimmte Netzwerkressourcen autorisiert, wie in der Abbildung dargestellt.



Accounting

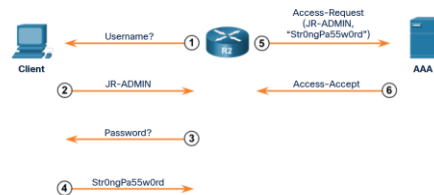
Die Abrechnung (Accounting) erfolgt über einen AAA-Server. Dieser Dienst übermittelt Nutzungsstatistiken an den ACS-Server. Diese Statistiken können extrahiert werden, um detaillierte Berichte über die Netzwerkconfiguration zu erstellen.

Folgende Accounting (Abrechnungsinformationen) werden typischerweise erfasst:

- Netzwerk-Accounting
- Verbindungs-Accounting
- EXEC-Accounting
- System-Accounting
- Befehls-Accounting

RADIUS

- Der Remote Authentication Dial In User Service (RADIUS) ist in **RFC 2865** definiert.
- Ursprünglich** diente es der Authentifizierung von Einwahlkunden und wird für **Einwahlleitungen und 3G-Netze** verwendet.
- Ziel ist eine **zentrale Benutzerdatenbank** für Passwörter und andere Benutzerinformationen.
- RADIUS ist **kosteneffizient** und einfach zu konfigurieren.
- RADIUS vereint **Authentifizierung und Autorisierung in einem einzigen Prozess**.
- Er wird zusammen mit einem **Authentifizierungsprotokoll** verwendet.
- Ein **Client-Server-Protokoll**.
 - Der Netzwerkzugriffsserver (NAS) fungiert als Client.
 - Der Radius-Server ist ein Server.
- Die Sicherheit basiert auf einem zuvor **geteilten Geheimnis**.
- Das RADIUS-Protokoll **verschlüsselt Passwörter** während der Übertragung. Der Rest des Pakets wird jedoch im Klartext übertragen.
- Mehrere Server können einen einzelnen Client bedienen.
- Ein Server kann als **Proxy** fungieren.
- Basiert aus Effizienzgründen auf **UDP**.
- Keine Keep-Alive-Signalisierung**.



RADIUS Signale

Der RFC definiert die folgenden Signale:

- 1 Zugriffsanfrage
- 2 Zugriffsbestätigung
- 3 Zugriffsablehnung
- 4 Abrechnungsanfrage
- 5 Abrechnungsantwort
- 11 Zugriffsherausforderung
- 12 Serverstatus
- 13 Clientstatus
- 255 Reserviert

RADIUS Limitierungen

- **Skalierbarkeit**
 - Keine explizite Unterstützung für Agenten, Proxys usw.
 - Manuelle Konfiguration gemeinsam genutzter Geheimnisse
 - **Zuverlässigkeit**
 - UDP ist nicht zuverlässig, Abrechnungsinformationen können verloren gehen
 - Definiert keine **Failover-Mechanismen**
 - Implementierungsspezifisch
 - **Mobilitätsunterstützung**
 - **Sicherheit**
 - Wird üblicherweise in vertrauenswürdigen Netzwerksegmenten oder VPNs eingesetzt
 - Anwendungsauthentifizierung und -integrität nur für Antwortpakete (Accept, Reject, ...). Enthalten einen sogenannten Response Authenticator, der mit dem Shared Secret berechnet wird
 - Keine Vertraulichkeit pro Paket
- **Diameter** behebt einige Sicherheitsprobleme

Diameter

- Ein Netzwerkprotokoll zur **Bereitstellung von AAA-Diensten für Roaming-Benutzer**.
- **Ersatz für RADIUS, Kerberos und TACACS+**. Das offene Basisprotokoll bietet Transport-, Nachrichtenübermittlungs- und Fehlerbehandlungsdienste. Das Diameter Base Protocol ist in RFC 3588 definiert.
- Es definiert die folgenden Funktionen:
 - Übermittlung von **AVPs** (Attribut-Wert-Paaren)
 - Aushandlung von **Capabilities** (Fähigkeiten)
 - **Fehlerbenachrichtigung**
 - **Erweiterbarkeit** durch zusätzliche Befehle und AVPs
- Nicht nur Nachrichtentransport sondern **auch grundlegende Dienste** wie Session-Mgmt., Accounting, Roaming Support, Fehler- und Zustandsmgmt., ...
- Verwendet **TCP** und SCTP für die Kommunikation.
- Kann mit **IPsec und TLS** gesichert werden.
- Ende-zu-Ende-Verschlüsselung wird empfohlen, ist aber nicht zwingend erforderlich.
- Basiert auf **Anfrage-Antwort-Signalpaaren**.
- Im Diameter-Netzwerk können **Clients, Relays, Proxys sowie Redirect- und Translation-Agenten** eingesetzt werden.

Diameter

- Ein Netzwerkprotokoll zur **Bereitstellung von AAA-Diensten** für **Roaming-Benutzer**.
- **Ersatz für RADIUS, Kerberos und TACACS+**. Das offene Basisprotokoll bietet Transport-, Nachrichtenübermittlungs- und Fehlerbehandlungsdienste. Das Diameter Base Protocol ist in RFC 3588 definiert.
- Es definiert die folgenden Funktionen:
 - Übermittlung von **AVPs** (Attribut-Wert-Paaren)
 - Aushandlung von **Capabilities** (Anwendungen und Erweiterungen die sie unterstützen) beim Verbindungsaufbau
 - **Fehlerbenachrichtigung**
 - **Erweiterbarkeit** durch zusätzliche Befehle und AVPs
- Nicht nur Nachrichtentransport sondern **auch grundlegende Dienste** wie Session-Mgmt., Accounting, Roaming Support, Fehler- und Zustandsmgmt., ...
- Verwendet **TCP** und SCTP für die Kommunikation.
- Kann mit **IPsec und TLS gesichert** werden.
- Ende-zu-Ende-Verschlüsselung wird empfohlen, ist aber nicht zwingend erforderlich.
- Basiert auf **Anfrage-Antwort-Signalpaaren**.
- Im Diameter-Netzwerk können **Clients, Relays, Proxys sowie Redirect- und Translation-Agenten** eingesetzt werden.

Diameter erforderliche Funktionen

Das Diameter-Protokoll unterstützt die folgenden erforderlichen Funktionen:

- **Übertragung von Benutzerauthentifizierungsinformationen**, damit der Diameter-Server den Benutzer authentifizieren kann.
- **Übertragung von dienstspezifischen Autorisierungsinformationen** zwischen Client und Servern, damit die Teilnehmer entscheiden können, ob eine Zugriffsanfrage eines Benutzers gewährt wird.
- **Austausch von Informationen zur Ressourcennutzung**, die beispielsweise für Abrechnungszwecke und Kapazitätsplanung verwendet werden können.
- **Weiterleitung, Proxying und Umleitung von Diameter-Nachrichten** innerhalb einer Serverhierarchie.

Diameter Features

- SCTP ersetzt UDP
 - Zuverlässiger Transport, Vermeidung von Überlastung, Flusssteuerung
- Keep-Alive-Nachrichten implementiert
 - Diameter erkennt lokale Ausfälle von Peers
 - Failover
- Peer-to-Peer ersetzt Client-Server
 - Jeder Knoten kann eine Anfrage initiieren
 - Peer-Erkennung und Austausch von Fähigkeiten
- Unterstützung von Zeitstempeln
 - Schutz vor Replay-Angriffen
- Unterstützung für Erweiterungen
- IPsec- und TLS-Unterstützung
- Ende-zu-Ende-Sicherheit

Diameter und LTE

Teilnehmerauthentifizierung MME ↔ HSS

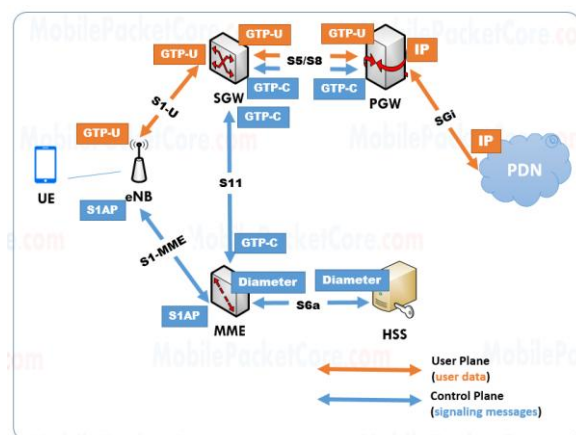
- Smartphone meldet sich im LTE-Netz an und MME (Mobility Management Entity) fragt beim HSS (Home Subscriber Server) an.
- Diameter transportiert die Authentifizierungsinformationen.

Policy und QoS-Steuerung P-GW ↔ PCRF

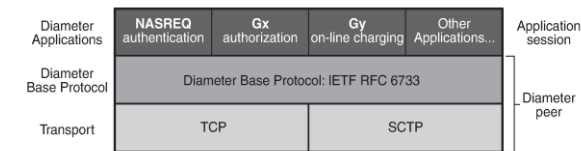
- P-GW (Packet Data Network Gateway) fragt bei PCRF (Policy and Charging Rules Function) die QoS Parameter und Tarife ab

Roaming Visited Network ↔ Home Network

- Kunde von Österreich befindet sich im Ausland.
- Das besuchte Netz kommuniziert über Diameter mit dem Heimnetz.
- Authentifizierung und Profilverechnungen werden ausgetauscht.



Diameter Protokollstack und Netzwerktopologie (Beispiel Nokia)



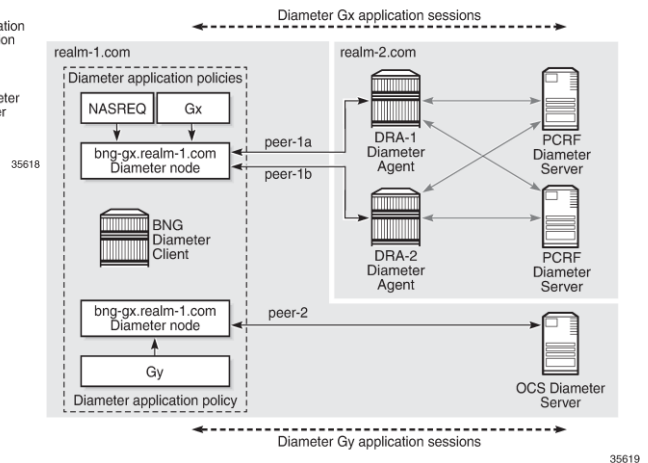
Teilnehmerauthentifizierung MME ↔ HSS

NASREQ Application

- Diameter-Anwendung für Network Access Server
- Definiert AAA-Nachrichten für VPN, WLAN, Dial-In usw.

Diameter Base Protocol

- RoutingSession Management
- Capability Negotiation
- Fehlermanagement



tgm [Quelle: <https://documentation.nokia.com/acg/23-7-2/books/classic-cli-part-iii/c067-est-diameter-peering-session.html>] - letzter Abruf 6.8.2026]

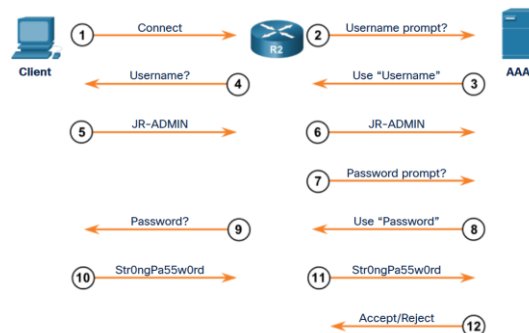
tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

21

21

TACACS+

TACACS+ ist eine Erweiterung des ursprünglichen TACACS-Protokolls von Cisco.



tgm [Quelle: Module 7: Authentication, Authorization, and Accounting (AAA), Networking Security v1.0 (NETSEC)]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

22

22

02

RADIUS

24

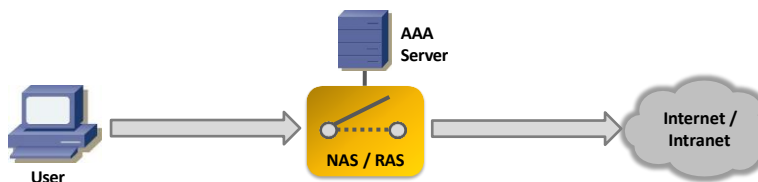
IT-SICHERHEIT / SEMESTER 5 und 6

AAA (Wiederholung)

Der **Begriff AAA (ausgesprochen „Triple A“)** umfasst die Funktionen, die beim Netzwerkzugriff verwendet werden, um einem Benutzer oder Computer den Zugriff auf ein Netzwerk und die Nutzung seiner Ressourcen zu ermöglichen.

- **Authentifizierung:** Ist die Person, mit der ich kommuniziere, diejenige, für die sie sich ausgibt (ist der Benutzer authentisch)?
- **Autorisierung:** Ermitteln, welche Aktionen der Benutzer ausführen darf (und welche nicht).
- **Abrechnung:** Protokollieren der Benutzeraktivitäten zur Abrechnung. Abrechnungsinformationen können zur Nachverfolgung der Benutzernutzung für Abrechnungszwecke, aber auch für Prüfungszwecke verwendet werden.

AAA wird in Szenarien eingesetzt, in denen ein **NAS (Network Access Server)** oder ein **RAS (Remote-Access-Server)** als Switch fungiert und einem Benutzer basierend auf AAA-Authentifizierung und -Autorisierung den Zugriff auf das Internet oder Intranet gewährt oder verweigert.



25

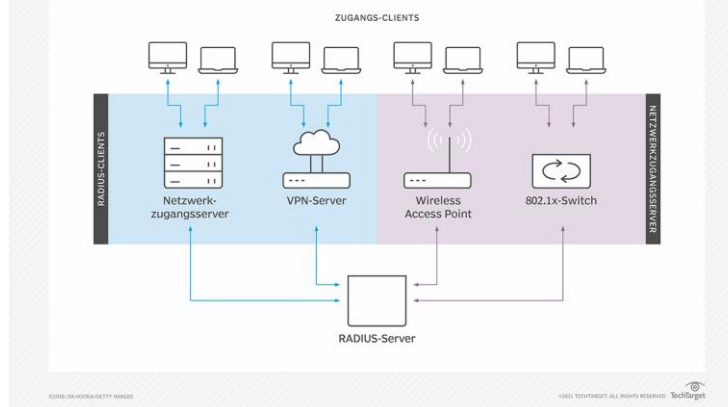
Wichtigsten AAA Protokolle

- **RADIUS RFC2865:** Remote Authentication Dial-In User Service (RAID).
- **TACACS+ RFC1492:** Terminal Access Controller Access Control System von Cisco.
- **Diameter RFC3588:** Diameter ist kein Akronym. Diameter ist der Nachfolger von RADIUS und soll einige der Schwächen von RADIUS beheben. Diameter nutzt zuverlässige Transportverbindungen und läuft über TCP oder SCTP (Stream Control Transmission Protocol).

Wichtig:

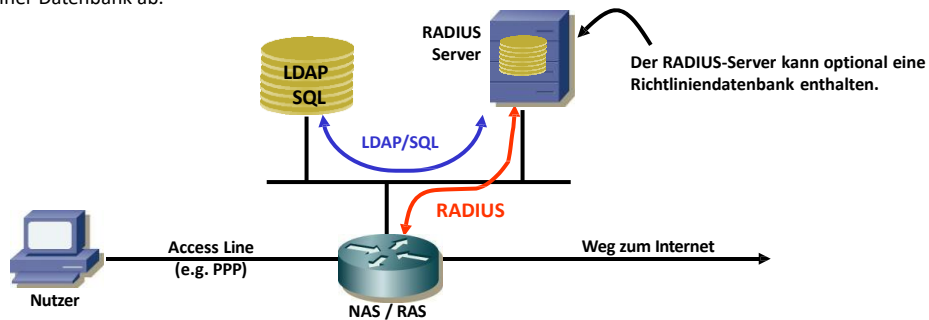
- **RADIUS (und TACACS+) sind AAA-Zugriffskontrollprotokolle, definieren aber keine Zugriffsrichtlinie** (wer Zugriff erhält, was der Benutzer tun darf usw.). Diese Protokolle bieten lediglich eine Möglichkeit, solche Informationen zwischen einem Client und einem Authentifizierungsserver zu übertragen.
- Die **Zugriffsrichtlinie wird als Anwendung auf dem RADIUS-Server implementiert** (möglicherweise durch LDAP/SQL-Abfragen, um Zugriffsregeln zu erhalten).

Architektur des RADIUS-Protokolls



RADIUS Architektur (Szenario 1)

- In diesem Szenario authentifiziert ein Frontend-NAS (Network Access Server) oder RAS (Remote-Access-Server) einen Benutzer gegenüber einem Backend-RADIUS-Server.
- Der NAS/RAS sendet Benutzerinformationen (Anmeldeinformationen) in RADIUS-Paketen an den RADIUS-Server. Dieser implementiert die Zugriffsrichtlinie (wer erhält welche Berechtigungen) oder ruft Richtlinien über LDAP (Lightweight Directory Access Protocol) aus einer Datenbank ab.



tgm [Quelle: Introduction to Radius, a protocol for authentication, authorization and accounting services, Peter R. Egl, indigo.com]

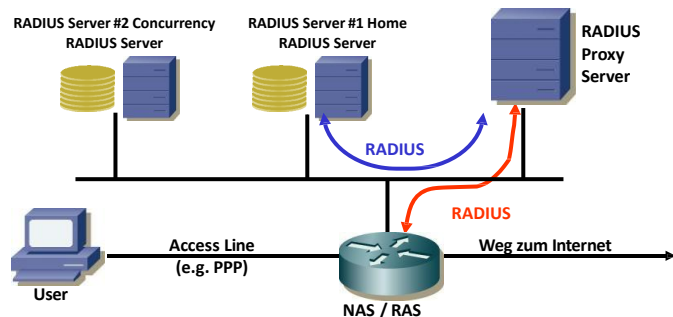
tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

28

28

RADIUS Architektur (Szenario 2)

- In diesem Szenario führt ein erster RADIUS-Server keine Authentifizierung durch, sondern fungiert als Proxy, der RADIUS-Anfragen an den entsprechenden Home-RADIUS-Server weiterleitet.
- Das Routing erfolgt anhand von Benutzernamen und Realm.
- Der Home-RADIUS-Server führt die eigentliche Authentifizierung durch Zugriff auf eine Benutzerdatenbank durch.
- Ein paralleler RADIUS-Server kann eingesetzt werden, um sicherzustellen, dass sich ein Benutzer nicht mehrfach anmeldet, z. B. in Szenarien mit mehreren RADIUS-Servern zur Redundanz oder Lastverteilung.



tgm [Quelle: Introduction to Radius, a protocol for authentication, authorization and accounting services, Peter R. Egl, indigo.com]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

29

29

RADIUS RFC2865 Protokoll

RADIUS verwendet UDP (Port 1842), da es sich um ein einfaches Anfrage-Antwort-Protokoll (Annehmen/Anfordern) handelt.

RADIUS-Paketformat:

Byte 0	Byte 1	Byte 2	Byte 3
Code	Identifier		Length
Authenticator			
List of attributes			

Code field: Defines the packet type (Access-Request, Access-Accept, Access-Reject, Access-Challenge, Accounting-Request, Accounting-Response).

Identifier: ID to match requests and replies.

Length: Length of packet.

Authenticator: Used to authenticate the RADIUS transaction itself. The authenticator authenticates the reply from the server. The RADIUS client sends a challenge in the Access-Request packet and the RADIUS server returns a challenge-response in the Authenticator field (shared secret between NAS and RADIUS server).

Attributes: AAA-information such as username, password, CHAP-Password, callback-phone-# etc. The attribute encoding is as follows:

Type	Length	Value
------	--------	-------



[Quelle: Introduction to Radius, a protocol for authentication, authorization and accounting services, Peter R. Egl, indigo.com]

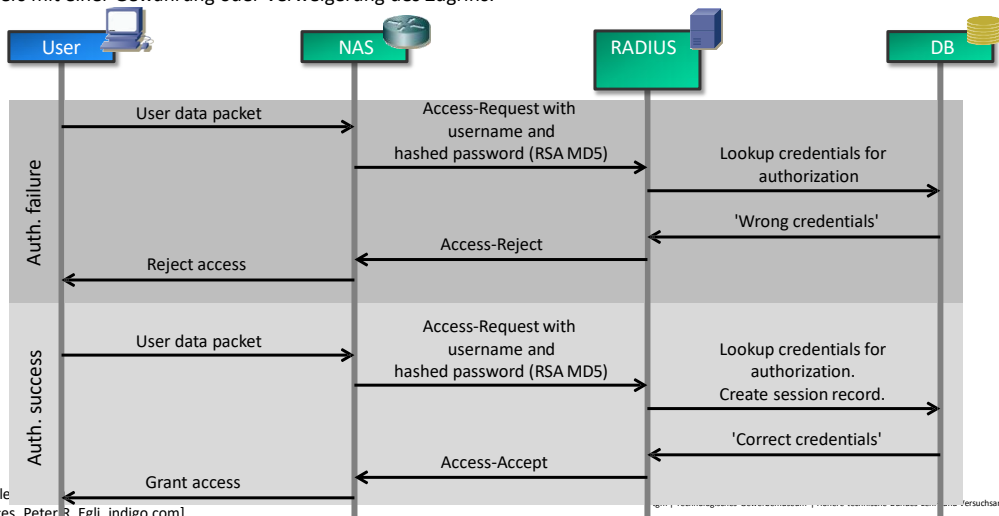
tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

30

30

RADIUS Transaktion

Eine RADIUS-Transaktion beginnt typischerweise mit einer Zugriffsanfrage, die Benutzerdaten enthält, gefolgt von einer Antwort des RADIUS-Servers mit einer Gewährung oder Verweigerung des Zugriffs.



[Quelle: Introduction to Radius, a protocol for authentication, authorization and accounting services, Peter R. Egl, indigo.com]

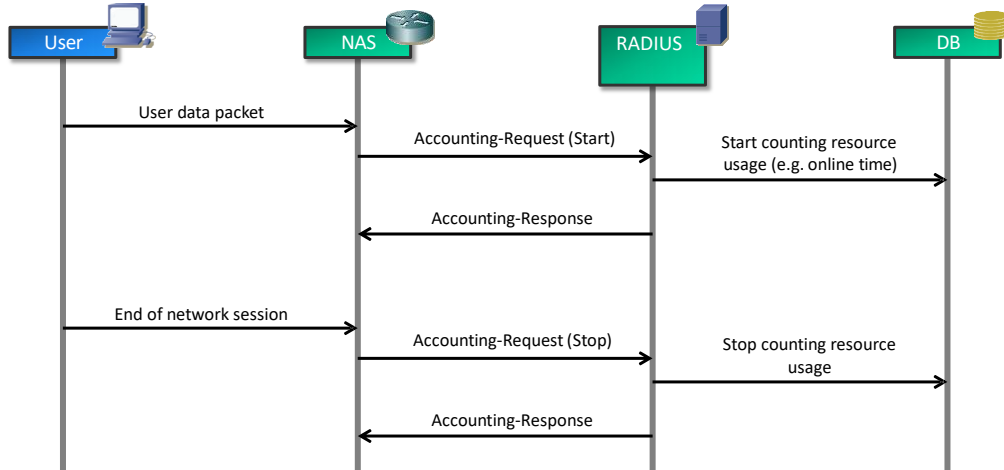
tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

31

31

RADIUS Accounting RFC2866

Sobald eine Netzwerkverbindung hergestellt und aktiv ist (erfolgreiche Authentifizierung), kann das NAS anfordern, die Netzwerknutzung des Benutzers zu erfassen.



tgm [Quelle: Introduction to Radius, a protocol for authentication, authorization and accounting services, Peter R. Egl, indigo.com]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

32

32

RADIUS Accounting RFC2866

Die Abrechnung mit RADIUS ist in einem separaten RFC (RFC2866) spezifiziert. Zur Übertragung von Abrechnungsdaten zwischen dem RADIUS-Client (NAS) und dem Server werden spezielle Abrechnungsattribute für RADIUS (Attributwerte 40–59) verwendet.

Value	Type	Description
40	Acct-Status-Type	Indicates start or stop of accounting.
41	Acct-Delay-Time	Delay between event causing accounting request and server response (used to compensate for processing delay time).
42	Acct-Input-Octets	Used by client to report number of received octets to server.
43	Acct-Output-Octets	Used by client to report number of transmitted octets to server.
44	Acct-Session-Id	Used by client to identify user session to server.
45	Acct-Authentic	Used by client to report authentication method to server, e.g. user authenticated by NAS itself, user authenticated by RADIUS or user authenticated by external protocol.
46	Acct-Session-Time	Used by client to report to server how many seconds the user session is running.
47	Acct-Input-Packets	Used by client to report number of packets received by a user.
48	Acct-Output-Packets	Used by client to report number of packets sent by a user.
49	Acct-Terminate-Cause	Used by client to report cause of service termination (e.g. error, termination upon user request, timeout).
50	Acct-Multi-Session-Id	Similar to Acct-Session-Id, but used to link multiple sessions to one for correlation in log file.
51	Acct-Link-Count	Used by client to report number of links used by user.

tgm [Quelle: Introduction to Radius, a protocol for authentication, authorization and accounting services, Peter R. Egl, indigo.com]

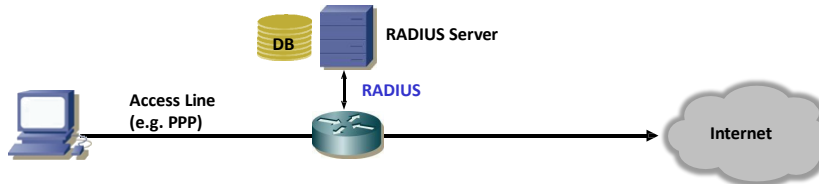
tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

33

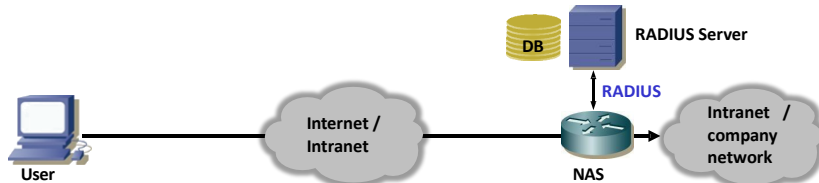
33

RADIUS Anwendungen

NAS-Netzwerkzugriff (ISP): Ein Benutzer wählt sich in einen vom Internetanbieter betriebenen NAS-Server ein. Bevor der Benutzerzugriff gewährt wird, authentifiziert der NAS-Server ihn per RADIUS.



RAS Intranet access (enterprise dial-in): Diese Anwendung ähnelt dem NAS-Szenario. Der RAS (Remote Access Server) befindet sich am Rand des Unternehmensnetzwerks und authentifiziert einen Benutzer, bevor er ihm Zugriff auf das Netzwerk gewährt.



tgm [Quelle: Introduction to Radius, a protocol for authentication, authorization and accounting services, Peter R. Egli, indigo.com]

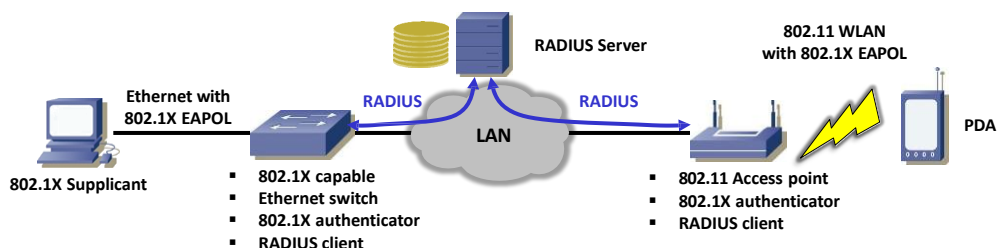
tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

34

34

802.1X-Backend-Steuerung für Ethernet- und WLAN-Netzwerkzugriff

- IEEE 802.1X ist ein generisches Protokoll zur Authentifizierung und Autorisierung in IEEE-802-basierten Netzwerken.
- Der 802.1X-Supplicant (der Benutzer) sendet eine EAPOL-Nachricht (Extensible Authentication Protocol Over LAN) an den 802.1X-Authenticator (Switch, Access Point).
- Der Switch oder Access Point aktiviert den Ethernet- oder WLAN-Port, wenn die Backend-Authentifizierung basierend auf den über 802.1X übermittelten Anmeldeinformationen erfolgreich war.
- Die Verwendung eines zentralen Servers für die Authentifizierung (Speicherung von Benutzername und Passwort) vereinfacht die Administration in großen Netzwerken.



tgm [Quelle: Introduction to Radius, a protocol for authentication, authorization and accounting services, Peter R. Egli, indigo.com]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

35

35

02

802.1x

36

IT-SICHERHEIT / SEMESTER 5 und 6

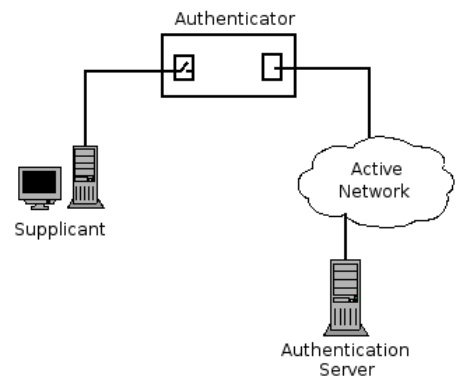
Einführung

802.1X ist ein Verfahren zur Authentifizierung einer neuen Verbindung in einem LAN.

Das **portbasierte Authentifizierungsprotokoll** (Port-Based Authentication Protocol, BAP) besteht aus drei Komponenten:

- dem **Supplicant**,
- dem **Authenticator**
- und dem **Authentifizierungsserver**.

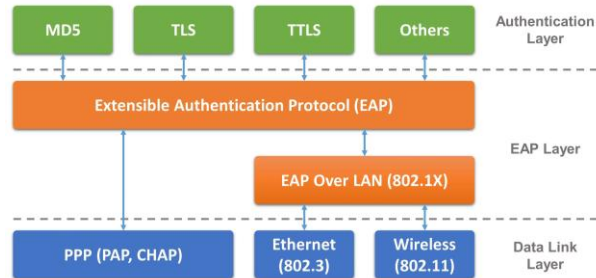
802.1X **basiert auf EAP (Extensible Authentication Protocol)**. EAP ist ein Rahmenprotokoll.



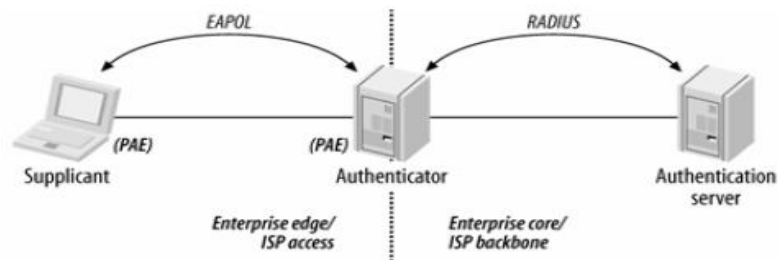
37

Extensible Authentication Protocol Architektur

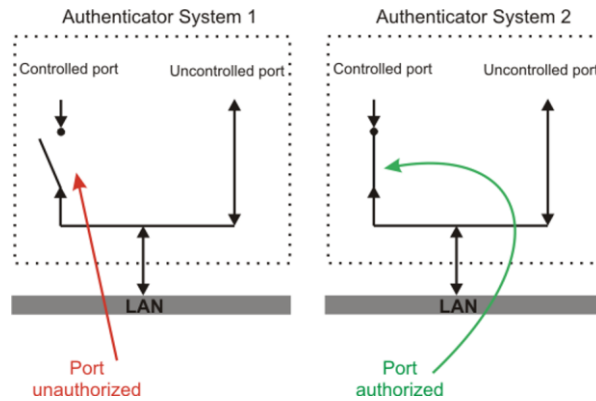
IEEE-802.1X ist ein Framework, das eine IEEE-Adaption von EAP (RFC 3748) darstellt und dynamische Schlüssel generiert, sobald sich ein Gerät mit einem WLAN-Netzwerk verbindet. Es ist auch als **Extensible Authentication Protocol over Wireless (EAPoW)** oder **Extensible Authentication Protocol over LAN (EAPoL)** bekannt. Daher sind die Schlüssel selbst dann unterschiedlich, wenn sich dasselbe Gerät erneut mit dem Netzwerk verbindet.



802.1X Architektur



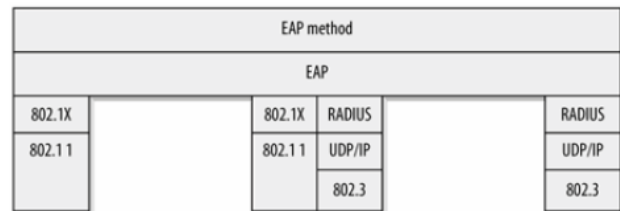
802.1X Architektur



802.1X logische Protokollarchitektur

Ablauf

1. Der Authentifizierungsaustausch erfolgt logisch zwischen dem Client und dem Authentifizierungsserver.
2. Der Authentifikator fungiert dabei lediglich als Vermittler.
3. Vom Client zum Authentifikator (dem „Frontend“) wird das Protokoll EAP over LANs (EAPOL) verwendet.
4. Auf dem „Backend“ wird EAP in RADIUS-Paketen übertragen (EAP over RADIUS).



EAP Authentication Methoden

Type code	Authentication protocol	Description
4	MD5 Challenge	CHAP-like authentication in EAP
6	GTC	Originally intended for use with token cards such as RSA SecurID
13	EAP-TLS	Mutual authentication with digital certificates
21	TTLS	Tunneled TLS; protects weaker authentication methods with TLS encryption
25	PEAP	Protected EAP; protects weaker EAP methods with TLS encryption
18	EAP-SIM	Authentication by mobile phone Subscriber Identity Module (SIM)
29	MS-CHAP-V2	Microsoft encrypted password authentication; compatible with Windows domains

EAP-TLS (Transport Layer Security)

Stellt einen **vertrauenswürdigen Kommunikationskanal über ein nicht vertrauenswürdiges Netzwerk** her.

Gegenseitige Authentifizierung durch **Zertifikatsaustausch**.

- Der Benutzer muss ein digitales Zertifikat vorlegen.
- Der Authentifizierungsserver muss ebenfalls ein Zertifikat bereitstellen.
- Die Validierung erfolgt durch Überprüfung des Zertifikats bei einer **Liste vertrauenswürdiger Zertifizierungsstellen**.

Erfüllt alle drei Anforderungen an drahtlose Netzwerke.

- Zertifikate bieten starke Authentifizierung.
- Gegenseitige Authentifizierung durch Zertifikate.
- Es wird ein Master-Secret eingerichtet, aus dem Schlüssel abgeleitet werden können.

Nachteile:

- Verwendet digitale Zertifikate sowohl für die Benutzer- als auch für die Serverauthentifizierung.
- Haupt Herausforderung: Generierung und Verteilung von Zertifikaten.
- Haupt Hindernis: Notwendigkeit einer Public-Key-Infrastruktur (PKI).

EAP-TTLS und EAP-PEAP

Tunneled TLS (TTLS) und Protected EAP (PEAP) erweitern TLS.

- Beide Verfahren funktionieren ähnlich.

Die Methode umfasst **zwei Schritte**:

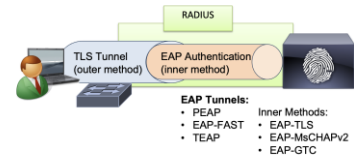
- Aufbau eines **TLS-Tunnels**: Digitale Zertifikate auf dem Authentifizierungsserver dienen der Netzwerkvalidierung.
- Der **TLS-Tunnel verschlüsselt das Authentifizierungsprotokoll**, das den Benutzer im Netzwerk authentifiziert.
- Der erste Schritt ist die „äußere“ Authentifizierung, der zweite die „innere“ Authentifizierung.**

Vorteile:

- Zertifikate werden nur für die äußere Authentifizierung benötigt.
- Für die innere und äußere Authentifizierung können unterschiedliche Benutzernamen verwendet werden.

Unterschied:

- TTLS** nutzt den verschlüsselten Kanal zum **Austausch von Attribut-Wert-Paaren (AVPs)**.
- PEAP** nutzt den verschlüsselten Kanal, um einen **zweiten EAP-Austausch innerhalb des Tunnels** zu starten.



MD-5 (Message Digest) Challenge

Wichtig

- Nicht für den direkten Einsatz in drahtlosen Netzwerken geeignet.**
- Nützlich als interne Authentifizierungsmethode mit PEAP oder TTLS.**
- Benutzerauthentifizierung per Passwort
- Authentifizierungsanfragen enthalten eine Herausforderung an den Endbenutzer.
- Der Endbenutzer verschlüsselt die Herausforderung mit einem gemeinsamen Geheimnis (Passwort).
- Alle EAP-Implementierungen müssen die MD5-Herausforderung unterstützen.
- Nicht weit verbreitet in drahtlosen Netzwerken, da keine Schlüsselverwaltung oder dynamische Schlüssel vorhanden sind.

EAP-MSCHAP-V2

Wichtig

- **Nicht für den direkten Einsatz in drahtlosen Netzwerken geeignet.**
- **Nützlich als interne Authentifizierungsmethode mit PEAP oder TTLS.**
- Ursprünglich in Windows 2000 eingeführt.
- Entwickelt, um die Nachteile von MS-CHAP zu beheben,
 - indem die schwache Verschlüsselung von Passwörtern für ältere Clients beseitigt,
 - eine gegenseitige Authentifizierung ermöglicht
 - und die Schlüsselerzeugung verbessert wird.
- Wird häufig als interne Authentifizierungsmethode mit PEAP unterstützt und verwendet.



[Quelle: 802.11 Wireless Networks: The Definitive Guide, Chapter 6. User Authentication with 802.1X, Matthew S. Gast, O Reilly]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

46

46

EAP-SIM (Subscribers Identity Module) und EAP-AKA (Authentication and Key Agreement)

Wichtig

- **Nicht für den direkten Einsatz in drahtlosen Netzwerken geeignet.**
- **Nützlich als interne Authentifizierungsmethode mit PEAP oder TTLS.**
- Beide Methoden dienen der Authentifizierung gegenüber Mobilfunkdatenbanken.
- EAP-SIM nutzt die SIM-Datenbank von GSM-Telefonnetzen.
- EAP-AKA basiert auf dem Authentifizierungssystem von Mobilfunknetzen der dritten Generation.



[Quelle: 802.11 Wireless Networks: The Definitive Guide, Chapter 6. User Authentication with 802.1X, Matthew S. Gast, O Reilly]

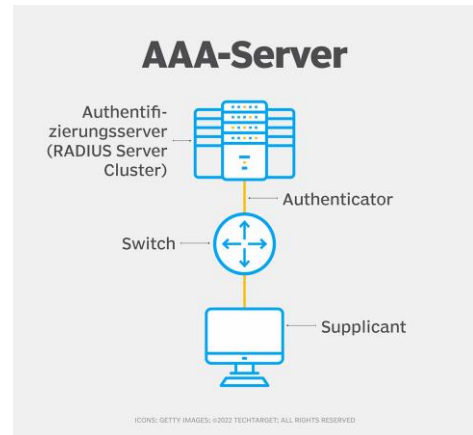
tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

47

47

Begriffe

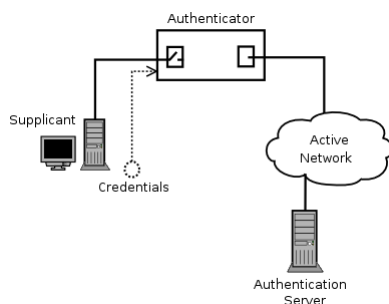
- **Authentifikator** – Eine Entität an einem Ende eines Punkt-zu-Punkt-LAN-Segments, die die Authentifizierung der am anderen Ende dieser Verbindung angeschlossenen Entität ermöglicht.
- **Authentifizierungsserver** – Eine Entität, die einem Authentifikator einen Authentifizierungsdienst bereitstellt. Dieser Dienst ermittelt anhand der vom Anfragenden (Supplicant) übermittelten Anmeldeinformationen, ob der Anfragende berechtigt ist, auf die Dienste des Systems zuzugreifen, in dem sich der Authentifikator befindet. Üblicherweise ein RADIUS-Server (Remote Authentication Dial-In Service).
- **Anfragender (Supplicant)** – Eine Entität an einem Ende eines Punkt-zu-Punkt-LAN-Segments, die sich von einem am anderen Ende dieser Verbindung angeschlossenen Authentifikator authentifizieren lassen möchte.



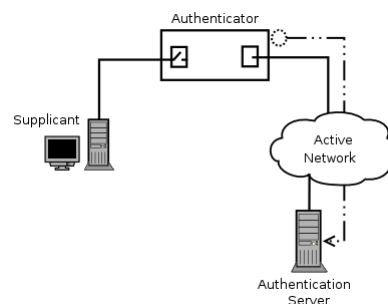
Funktion

Schritt 1 - Der Antragsteller übermittelt dem Authentifikator Anmeldeinformationen.

Der Antragsteller hat derzeit keinen Zugriff auf das aktive Netzwerk. Er kann nur mit dem Authentifikator kommunizieren.

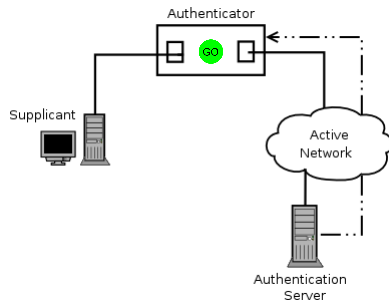


Schritt 2 - Da der Authenticator Zugriff auf den Authentifizierungsserver hat, übermittelt er die Anmeldeinformationen über eine verschlüsselte Verbindung.

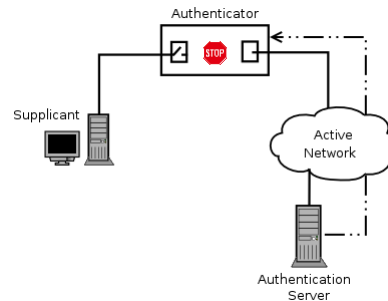


Funktion

Schritt 3a - Stimmen die Anmeldeinformationen mit den in der Datenbank des Authentifizierungsservers gespeicherten Daten überein, wird dem Client die Verbindung zum LAN gestattet.



Schritt 3b - Stimmen die Anmeldeinformationen nicht mit den in der Datenbank des Authentifizierungsservers gespeicherten Daten überein, wird dem Antragsteller der Zugriff auf das LAN auf allen Ebenen außer der physikalischen Schicht verweigert.



Supplicant

- Der Client ist ein Softwareprogramm, das auf dem Betriebssystem des Computers ausgeführt wird, der versucht, eine LAN-Verbindung herzustellen.
- Die vom Client übermittelten Informationen hängen von den verwendeten Authentifizierungsmethoden ab.

Die aktuell getesteten Authentifizierungsprotokolle sind:

- MD5-Challenge:** Benutzername, Passwort und Domäne werden übermittelt.
- PEAP (Protected Extensible Authentication Protocol):** Benutzername, Passwort, Domäne und Zertifikat werden übermittelt.
- EAP-TTLS (Extensible Authentication Protocol-Tunneled Transport Layer Security):** Benutzername, Passwort, Domäne (innere Identität) und ein anonymer Benutzername (äußere Identität) werden übermittelt.

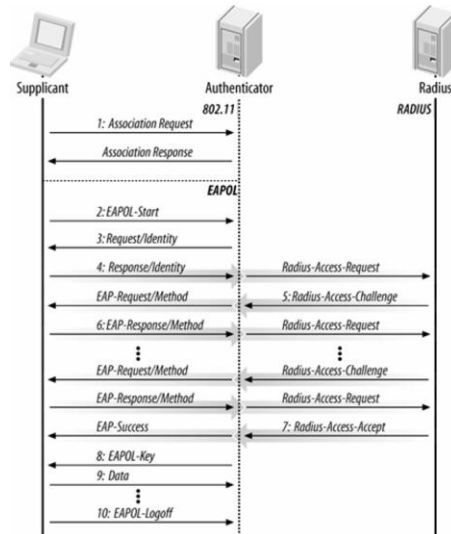
Authenticator

- Der Authenticator ist **üblicherweise ein Switch**, der mit den 802.1X-Protokollen ausgestattet ist und mit einem RADIUS-Server kommunizieren kann.
- Der Authenticator **speichert die IP-Adresse des RADIUS-Servers** sowie ein **gemeinsames Geheimnis (Shared Secret)** zwischen ihm und dem Server. Mithilfe dieses Geheimnisses signalisiert er dem Server, dass er ein autorisierter Authenticator ist.
- Der Authenticator steuert außerdem, welche Ports 802.1X unterstützen.
- Ports, für die 802.1X aktiviert ist, werden als kontrollierte Ports bezeichnet.
- Ports, für die 802.1X deaktiviert ist, werden als unkontrollierte Ports bezeichnet. Unkontrollierte Ports benötigen keine Authentifizierung und können sofort auf das LAN zugreifen.

Authentication Server

- Der Authentifizierungsserver ist **üblicherweise ein RADIUS-Server**.
- Auf dem RADIUS-Server befinden sich eine **Datenbank mit Benutzernamen und Passwörtern** sowie ein **Serverzertifikat**. Viele RADIUS-Server verfügen zusätzlich über einen Zertifizierungsstellenserver (Certificate Authority Server), dies ist jedoch nicht zwingend erforderlich.
- Der RADIUS-Server verwendet die vom Benutzer für das LAN zugelassenen **Authentifizierungsprotokolle (z. B. MD5-Challenge, PEAP, TTLS)**.

802.1X in drahtlosen LANs - Beispiel eines 802.1X-Austauschs auf 802.11



Beispielhafter EAP Austausch

EAP-Methodenaustausche werden als Request/Method geschrieben, wenn sie vom Authentifikator kommen, und als Response/Method, wenn sie als Antwort gesendet werden.

